

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Operator of anonymous review, whistleblowing, informant, or reputation deployment
DPO or similar function	Controller DPO or privacy contact
Repository evidence	Consumers/INFORMANT_STREAM; anonymous review flows; private surfaces; patent/m

Name of the Processing

Internal name: Shyware Informant Stream / Anonymous Review DPIA

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category
1	Anonymous report/review payload	Allegation, review, evidence, or narrative content
2	Subject data	Named individual, employer, platform user, or organization being reviewed
3	Submitter eligibility/identity hash	Scoped pseudonymous identity, proof, or anti-abuse token
4	Moderation and abuse signals	Safety review, spam/fraud indicators, audit logs

Purposes of the Processing Enable anonymous or pseudonymous disclosure, review, reporting, moderation, abuse prevention, and limited auditability.

Nature, Scope and Context This domain can involve allegations, workplace harms, retaliation risk, defamation risk, and safety-sensitive reports. Even when submitter identity is structurally separated, content itself may identify the submitter or third parties.

ANALYSIS OF THE PROCESSING

Lawfulness and Minimisation

Customer controllers must define lawful basis, notice, moderation duties, and redress process for report subjects. Payload schemas should discourage unnecessary names, sensitive data, and unsupported allegations unless the use case requires them.

Mainhub Patent Alignment

The Mainhub patent architecture can reduce canonical-state linkage between a submitter commitment and an anonymous report record. It does not prevent a report’s content, writing style, timing, attachments, moderation metadata, or investigation workflow from identifying the submitter or third parties. Retaliation, defamation, correction, and abuse risks remain domain risks outside the canonical-state guarantee.

Authority Partition This is a count-match embodiment. Four structurally separated parties are required:

Authority	Role	
Auth (Cognito)	Account layer; always required; gates access to IDV/KYC stage	S
IDV/KYC (Didit)	Verifies user identity on authenticated users	C
Review authority	Determines domain eligibility; registered independently at scoping-identifier creation	I
Reconciling authority	Off-chain linkage store + sealer keys	I

Dual co-authorization enforcement (Claim 2): The validation layer must reject single-signature rescission transactions. **VERIFIED (run 26369476939):** *DUAL_COSIG section passes 379/379 — unauthenticated + valid token → 401; authenticated + no token → 400; both co-signatures → 200.*

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The informant stream pattern may be proportionate where anonymous or protected reporting is necessary to prevent retaliation or preserve public-interest reporting. It is not proportionate as a generic anonymous accusation tool without moderation, payload minimization, reporter protection, subject-rights handling, and legal review. Reveal or recovery should be disabled or dual-controlled unless a lawful process or safety policy requires it.

RISK ASSESSMENT AND MANAGEMENT

#	Risk	Required Follow-up
1	Retaliation or submitter deanonymization	Define content redaction, metadata stripping, and access controls
2	Harm to report subject	Define moderation, correction, dispute, and takedown process
3	Sensitive third-party data in payload	Add payload guidance and restricted-data controls
4	Abuse of anonymity	Define rate limits, eligibility, and audit controls without generat

DPIA Audit Findings

This DPIA is the audit record for informant stream and anonymous review deployments. Before production, the DPIA must identify the provider partition across authentication or eligibility

provider, moderation/review operator, protected linkage store, reconciling authority, canonical commit authority, and telemetry/support providers. Canonical-state unlinkability does not reduce risks from payload self-identification, retaliation, workplace or platform imbalance, defamation, lawful process, or moderator access. The software evidence for the core kernel may be complete while payload controls, reporter protection, moderation access, retention, and reveal policy still need to be fixed for this domain.

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** (`patent/mainhub/dpia/source/COM` published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key` $\neq$ `reconciling_authority_key` $\neq$ `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment

The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while report content, retaliation, moderation, subject-rights, legal, or customer-governance choices still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Payload self-identification	Reporter guidance, payload minimization, redaction, and moderation
Retaliation or workplace/platform harm	Reporter protection policy, access limits, and escalation controls
Moderator or operator access misuse	Least privilege, audit logs, dual-control reveal, and role partitioning
Defamation or third-party harm	Moderation workflow, takedown process, and legal review
Provider consolidation	Provider matrix for auth/eligibility, moderation, linkage, reconcile, c

INVOLVEMENT OF INTERESTED PARTIES

Privacy counsel, moderation/legal stakeholders, workplace or platform safety stakeholders where applicable, security, and customer DPO teams should review this DPIA before production. Representative consultation should be considered where employees, whistleblowers, vulnerable reporters, or accused third parties may be affected.

CONCLUSION AND DECISION

Draft decision: Separate DPIA required. Expand with moderation, redress, retaliation-risk, and content-governance controls.

Regulatory and Deployment Context Annexes

Annex A — Deployment Context Variants

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
Corporate whistleblower (EU)	Retaliation against reporter; identity exposure to investigated party	EU Whistleblower Protection Directive 2019/1937; national implementing laws	Internal channel required for 50+ employee organisations; acknowledgement within 7 days; feedback within 3 months; no disclosure of reporter identity to investigated party
US regulatory whistleblower	Identity exposure to employer; anti-retaliation protections vary by program	SEC Rule 21F; CFTC Rule 165; False Claims Act 31 U.S.C. §3729; SOX §806; OSHA 29 C.F.R. §1980	Submission must be capable of forwarding to SEC/CFTC without revealing reporter identity; counsel review of award-eligibility requirements before deployment
Journalistic source protection	State-level compelled disclosure; shield law variations	Shield laws vary by US state; EU Charter Art. 11 press freedom; ECHR Art. 10	No logging of submission metadata beyond canonical two-list records; source protection policy documented; legal hold procedure for court orders

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
HR / employment complaints	Retaliation; false accusations; data about third parties (accused)	GDPR Art. 9 if complaint involves health, union, religious data of accused; employment law	Data about the accused is third-party personal data requiring separate legal basis; retention limited to investigation period; access control preventing HR enumeration

Annex B — EU Whistleblower Protection Directive (2019/1937)

Directive 2019/1937 requires organisations with 50 or more employees to establish internal reporting channels. The structural requirements that shyrest-v1 addresses:

- **Confidentiality of reporter identity:** The Directive requires that reporter identity is not disclosed to the investigated party or to persons other than authorised staff. shyrest-v1's structural non-linkability means no canonical-state query returns the reporter's identity alongside the submission content. The reconciling authority API is non-enumerable and per-participant identity-gated, satisfying the operational confidentiality requirement.
- **Acknowledgement and feedback:** The Directive requires acknowledgement within 7 days and feedback on action taken within 3 months. shyrest-v1 must be configured to support an authenticated response path to the reporter without revealing reporter identity to the responder (the shyrest reconcile interface supports per-reporter authenticated retrieval without exposing the reporter's identity to other reporters or to the admin mailbox operator).
- **Prohibition on retaliation:** Structural anonymity reduces the practical ability of an employer to retaliate because submission-to-reporter linkage is not available from canonical state. The off-chain reconciling authority remains a residual risk; dual-control access policy is required.
- **National implementing laws:** All EU member states must have implemented by December 2023. Operators must confirm implementing legislation in each deployment jurisdiction (e.g., HinSchG Germany, loi Sapin II France, PIDA UK).

Annex C — US Whistleblower Programs

US whistleblower programs impose specific requirements on how submissions are received and forwarded:

- **SEC Rule 21F (Dodd-Frank):** Reporter identity must be protectable; anonymous submissions permitted if represented by counsel. The shyrest reconciling authority must be

capable of receiving an SEC subpoena without disclosing reporter identity from canonical state alone (structural guarantee holds; off-chain linkage requires separate legal process). Award eligibility requires the submission to be “original information” — the sealed canonical payload must be preservable as evidence without modification.

- **False Claims Act:** Qui tam actions require the relator’s identity to be disclosed to the government but not the defendant initially. shyrest’s sealed submission can be forwarded to the DOJ under confidential seal; reporter identity disclosed only per court order.
- **SOX §806 / OSHA:** Employer anti-retaliation protections apply from the date of submission. The canonical write timestamp (HSM-attested period-close) provides an independently verifiable submission-date record supporting retaliation claims.